

Social Engineering Awareness Campaign: Quid Pro Quo Attack Awareness

Author: Anene Ifunanya

Introduction

Social engineering is one of the most effective attack methods in a cybercriminal's toolkit. Its power does not come from technical sophistication. It comes from the fact that it targets people directly. It does not need to exploit a software vulnerability or bypass a firewall. It only needs someone to trust the wrong message.

This campaign was developed with a specific focus on Quid Pro Quo attacks. The goal was to educate participants on how these attacks work, help them recognise the warning signs, and equip them with practical steps to protect themselves and their organisations.

What set this project apart from a standard awareness presentation was that it was built on real evidence. Before the campaign was designed, an authorised phishing simulation was conducted on a real organisation. The findings shaped everything that came after.

Project Objectives

The objectives of this project were to:

- Increase awareness of social engineering threats, with a specific focus on Quid Pro Quo attacks.
- Use real simulation data to demonstrate the scale of the awareness gap.
- Assess current awareness levels among participants through a structured survey.
- Promote safer decision-making when handling unsolicited offers or requests.
- Provide actionable recommendations that employees can apply immediately.
- Encourage a culture of reporting suspicious activity within organisations.

Understanding Quid Pro Quo Attacks

The phrase "Quid Pro Quo" comes from Latin and means "something for something." In cybersecurity, it refers to a social engineering technique where an attacker offers something of value in exchange for information, access, or an action that compromises security. The offer might be a reward, technical assistance, or an exclusive benefit. What the victim does not realise is that the exchange is entirely in the attacker's favour.

What makes these attacks particularly effective is that they do not rely on fear or urgency the way traditional phishing does. They appeal to trust, curiosity, and the natural human inclination to respond positively to helpful or rewarding offers.

Common examples include:

- Fake gift card rewards attached to a survey.
- Impersonated technical support staff offering to fix a problem.
- Fraudulent software upgrade offers that require login credentials.
- False employee reward programmes appearing to come from HR.

The attacker's objective is consistent across all variations: convince the target to hand over something useful without realising they have been compromised.

Campaign Methodology

This project was carried out in two phases. The first was a group exercise that generated real susceptibility data from a live organisation. The second was an individual awareness campaign assigned to me by the training programme.

Phase 1: Phishing Simulation (Group Exercise)

Before any training content was developed, I and a team of 3 other trainees conducted an authorised phishing simulation with a logistics startup. The exercise had full authorisation from the training programme, and the company's management gave their complete awareness and consent for it to be carried out on their employees. This was a deliberate, sanctioned security assessment.

A simulated job opportunity link was sent to 25 employees via email. The message was crafted to resemble a legitimate external recruitment notice. Recipients were directed to a Google Form and asked to submit their details.

19 out of 25 employees clicked the link and provided their information. That is a susceptibility rate of 76 percent.

To put that in plain terms: more than three quarters of the people who received the email handed their credentials to a fake form without questioning it. The email was not technically complex. It did not use unusual language or suspicious formatting. It succeeded because it looked like something they might genuinely receive, and the offer seemed worth responding to.

Those results made one thing clear. Awareness training was not optional. It was overdue.

Phase 2: Awareness Campaign (Individual Assigned Project)

The Quid Pro Quo awareness campaign was assigned to me individually by the training programme. I designed and delivered it from start to finish, using the simulation findings as the evidence base for why the training was necessary.

The campaign was built around four components:

- **Threat Scenario Analysis:** A realistic workplace attack scenario was developed to make the threat tangible. The scenario centred on an HR impersonation email offering a \$500 reward for completing an employee feedback survey, mirroring the kind of offer the simulation had already shown employees would act on.

- **Baseline Assessment:** A survey of 15 participants was conducted to measure existing awareness levels and prior exposure to suspicious offers before the training session.
- **Training Design:** An 11-slide interactive presentation was built to walk participants through what Quid Pro Quo attacks are, how they operate, the warning signs to recognise, and the steps to take if targeted.
- **Recommendations:** Five practical steps were provided for employees to apply immediately, alongside five organisational-level recommendations for security teams.

Scenario Analysis

During the training session, participants were walked through a detailed attack scenario to make the threat feel real rather than theoretical.

An employee receives an email that appears to come from the company's Human Resources department. It informs them they have been selected for an employee feedback survey and will receive a \$500 reward on completion. The email is professionally formatted. The sender name matches the HR team. Nothing about it looks immediately suspicious.

The employee follows the link, which takes them to a website designed to resemble the company's internal portal. They log in with their work credentials and answer a short set of questions about their role and department. They submit the form and wait for their reward.

What they do not know is that the website belongs to an attacker. Their login credentials have been captured. The attacker now has access to their account, can escalate privileges, and has enough internal information to plan a more targeted attack on the organisation.

This scenario is not invented. Variations of it occur regularly across industries. The Phase 1 simulation confirmed that employees at the logistics company were already susceptible to exactly this type of approach.

Survey Findings

A survey was administered to 15 participants prior to the training session. The purpose was to establish a baseline understanding of how much exposure and awareness already existed within the group before any formal training took place.

The results showed:

- 47 percent (7 out of 15 participants) had personally experienced a suspicious offer or social engineering attempt.
- 40 percent (6 out of 15 participants) had no prior experience with suspicious offers.
- 13 percent (2 out of 15 participants) knew someone who had been targeted.

Nearly half the group had already encountered this category of attack in some form. The simulation had demonstrated that encountering an attack and recognising it for what it is

are not the same thing. The survey reinforced that finding. Prior exposure does not automatically translate into awareness.

Key Risk Indicators

A central component of the training focused on recognition. Participants were taught to identify the specific warning signs associated with Quid Pro Quo attacks so they could evaluate suspicious situations critically rather than reacting on instinct.

The following indicators were covered in detail:

- **Unsolicited offers:** Any unexpected reward, benefit, or offer of assistance that arrives without prior context should be treated with caution.
- **Requests for login credentials:** Legitimate organisations and systems do not typically ask for passwords through email or external forms.
- **Urgency:** Pressure to respond or act quickly is a common manipulation technique. Slowing down is itself a defensive action.
- **Offers that seem disproportionately generous:** If the reward seems unusually large or the opportunity unusually easy, that is worth questioning.
- **Unfamiliar or slightly altered links:** Checking the URL before entering any information can prevent a significant number of credential theft attempts.
- **Requests for internal organisational information:** Role, department, system access, and internal processes are all useful to an attacker conducting reconnaissance.

The core message delivered to participants was straightforward: the ability to recognise these signs is a learned skill. It is not something people either have or do not have. It can be developed through awareness, and this training was designed to start that process.

Recommendations

The following recommendations were developed based on the combined evidence from the phishing simulation and the survey findings.

For employees:

- Verify requests by contacting the supposed sender directly through official channels before taking any action.
- Avoid sharing passwords or credentials through email, external websites, or any form that arrived unexpectedly.
- Apply a consistent level of scepticism to unsolicited offers, regardless of how legitimate they appear.
- Engage with regular cybersecurity awareness training to stay informed about evolving tactics.
- Report suspicious messages promptly to IT security or the appropriate team within the organisation.

For security teams and organisations:

- Run authorised phishing simulations periodically to measure susceptibility and track improvement over time.
- Use simulation results as evidence when making the case for awareness training budgets and programme investment.
- Create an environment where employees feel comfortable reporting suspicious activity without fear of being blamed or judged.
- Classify security awareness as a formal governance control within the organisation's GRC framework, not a supplementary activity.
- Review training content on a regular basis to ensure it reflects current attack methods and does not become outdated.

Why This Matters in GRC

Security awareness is not a soft skill or a cultural nicety. ISO 27001 and the NIST Cybersecurity Framework both categorise it as a formal control requirement. That classification exists because the evidence consistently shows that technical controls, however well designed, cannot compensate for an uninformed workforce.

A 76 percent susceptibility rate on a live simulation involving real employees is the kind of finding that belongs in a risk register. It demonstrates a quantifiable gap in an organisation's human security layer. And unlike a misconfigured server or an unpatched system, this gap cannot be fixed with a software update. It requires deliberate, ongoing investment in awareness.

This project reinforced a principle that is fundamental to effective GRC practice: governance must reach the people operating within the systems being governed. Policies and frameworks set the standard. People determine whether that standard is actually met.

Lessons Learned

Several insights emerged from this project that extend beyond the awareness content itself.

- **Evidence transforms the conversation.** It is straightforward to tell people that social engineering works. It is far more effective to show them data from a real organisation that confirms it. The simulation findings gave the campaign a foundation that could not be dismissed as theoretical.
- **Scenario-based training is effective because it is specific.** Generic warnings about clicking suspicious links do not prepare people for the moment when a convincing, professionally written email lands in their inbox. A detailed, believable scenario does.
- **Trust is the primary attack surface in social engineering.** The simulation did not succeed because it was technically impressive. It succeeded because it was designed to look familiar and feel reasonable. Training needs to address the psychology of trust, not just the mechanics of attacks.

- **Measurement is a professional skill in GRC.** Without the simulation data and the survey results, this campaign would have been built on assumptions. Quantifying the risk, even roughly, is what turned a training exercise into an evidence-based intervention.

Conclusion

Quid Pro Quo attacks persist because they target something that technology cannot patch: the way people respond to trust and incentive. The simulation results illustrated this directly. Three quarters of the employees who received a convincing job opportunity email submitted their credentials without hesitation. They were not careless. They were human, and the attack was designed to work on human behaviour.

This project combined a live phishing simulation with a structured individual awareness campaign to address that vulnerability in a practical and measurable way. The data gathered from both phases provided evidence of where the gaps existed and what kind of training was most likely to close them.

The wider implication for GRC is this: a compliance programme that invests heavily in technical controls while neglecting the human layer is incomplete. The people within an organisation are not separate from its security posture. They are part of it. Educating and empowering them is not an additional responsibility. It is a core one.